

Cyber Defense (420-D03-AB)

Cyberdefense Fundamentals and Perimeter Security

Student handout — Classes 1 and 2 — Tuesday, September 1, 2026

Field	Value
Program	Cybersecurity AEC (Attestation d'études collégiales) — LEA.D8
Competency	EZ03 — To apply access control measures
Author and owner	Cyber.SoHo
Document version	1.0
Governing document	Legal Notice, Disclaimer, and Acceptable Use Policy — Cyber Defense (420-D03-AB), Version 1.0, effective August 29, 2026
Quiz	Q_01 (2.5%) is taken from these two sessions only

The two sessions this handout covers

The Saturday, August 29 session was cancelled. Its content is delivered together with the class of Tuesday, September 1. No deliverable, due date or grade weight changes.

Class 1 — Saturday, August 29 — Course Overview, Cyberdefense Fundamentals and Perimeter Security — LAB_01 (start)

Class 2 — Tuesday, September 1 — Cyberdefense Fundamentals and Perimeter Security — Q_01

About this printed version

A Word document cannot run code or show animation. The figures below are therefore still images, and the five interactive code players are linked instead. Open the players in any web browser — they need no installation, and they have Download, Copy, Reset, Start, Log and Pause controls so you can stop the execution at any step and study it.

1. The one rule that can never be broken

You practise only inside your own isolated laboratory, on machines you own — or on a system for which you hold explicit written permission, obtained before you start.

Unauthorized access to a computer is a criminal offence in Canada. The Criminal Code contains, among other provisions, section 342.1 (unauthorized use of a computer), section 342.2 (possession of a device to obtain unauthorized use of a computer) and section 430(1.1) (mischief in relation to computer data). Penalties can include imprisonment. If you are outside Canada, the law of your own country, province or state applies to you and you must know and obey it. The instructor never asks for, and never authorizes, any illegal act.

If an activity seems to touch a system you do not own, stop and ask the instructor before doing anything.

You may

- Practise inside your personal, isolated laboratory environment: a local virtualization tool such as VirtualBox, or your own personal free-tier cloud account on AWS (Amazon Web Services) or Microsoft Azure.
- Practise on any other system only with explicit written permission from its owner, obtained before you start.
- Use snapshots and isolated virtual networks, so a mistake stays inside your laboratory.

You must never

- Scan, probe, attack, intercept, monitor or access any system, network, wireless network or account that is not yours — including those of the college, an employer, a business, a public website, or a neighbour.
- Create, install or release malicious software outside your isolated laboratory.
- Attempt password, credential or interception attacks against any real account or any real communication.
- Use any tool from this course to break any law or any policy that applies to you.

Creativity and the AI rule

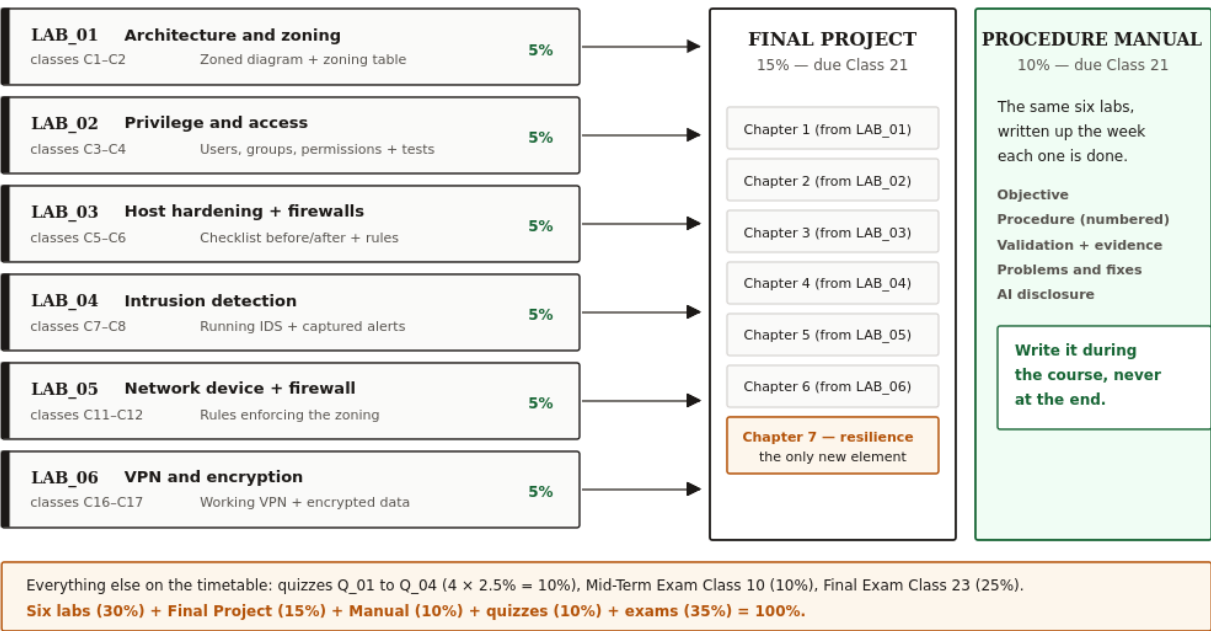
You may use AI (Artificial Intelligence) tools at any stage of this course, on one absolute condition: every chapter you submit that used an AI tool must state which LLM (Large Language Model) you used and the exact prompt you gave it. Not a summary of the prompt — the prompt. A chapter that used AI without that disclosure is an academic-integrity matter under the college's policies. You may also substitute equivalent open-source tools for the suggested ones, and you may write your own helper scripts; those belong to you.

2. Where this course is going

You are not doing three pieces of work. You are doing one piece of work, three times, in three formats. Every lab you finish is already a chapter of the Final Project and of the Course Procedure Manual. Write each lab up the same week you do it, and the Final Project is essentially finished by Class 17.

Figure 0 — Where this course is going, from Class 1 to Class 23

Every lab you finish is already a chapter of the Final Project and of the Course Procedure Manual.



Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 0 — How the six labs become the Final Project and the Course Procedure Manual.

Evaluation	Weight	When
Quizzes Q_01 to Q_04	4 × 2.5% = 10%	Classes 2, 9, 14, 18
Hands-on labs LAB_01 to LAB_06	6 × 5% = 30%	Throughout
Mid-Term Exam	10%	Class 10
Final Project	15%	Due Class 21
Course Procedure Manual	10%	Due Class 21
Final Exam	25%	Class 23
Total	100%	

3. What cyber defense means, and why one wall is not enough

Class 1 — Course Overview, Cyberdefense Fundamentals and Perimeter Security

The two properties

Defensible means the design makes defending it possible. A network where every machine reaches every other machine, where nobody knows what is connected, and where one password opens everything is not defensible — not because the defender is bad, but because the shape of the thing does not permit defence.

Cyber-resilient means the business keeps running during an attack and recovers after it. Notice what that does not say: it does not say nothing bad happens. Resilience assumes something will, and asks whether the company can still work on the Tuesday morning after.

Method, technique, tool

- A method is the approach: “divide the network into zones”.
- A technique is how you carry it out: “put the public web server in its own zone with its own firewall rules”.
- A tool is the software that does it: pfSense, OPNsense, Windows Defender Firewall, Snort. Tools change every two years; methods barely change at all.

Defence in depth

Layering several simple, imperfect protections instead of relying on one strong one. One control that stops 90% of attempts lets ten attempts in a hundred through. Five ordinary controls, each stopping only 70%, require an attempt to defeat all five — about two attempts in a thousand. Five mediocre layers beat one excellent wall, and they also fail differently: a firewall rule and a backup do not fail for the same reason on the same day.

Figure 2 — Defence in depth: five simple layers instead of one strong wall

Each layer is cheap and imperfect. The value is that they fail in different ways.

Layer 1 Perimeter filtering	Only published services are reachable from outside. Stops: untargeted scanning noise
Layer 2 Patching and hardening	Known weaknesses are removed before they are used. Stops: attacks against old software
Layer 3 Least privilege	Each account can reach only its own data. Stops: one account becoming every account
Layer 4 Detection (IDS and logs)	Unusual activity is recorded and raises an alert. Stops: quiet, long-running presence
Layer 5 Backup and recovery	Clean copies exist offline and are tested. Stops: a bad day becoming a closed business

Why layers, not one wall:

If a single control is 90% effective, one control lets 10 attempts in 100 through. Five different controls, each imperfect, must all fail on the same attempt.

Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 2 — Five layers, what each stops, and why layering works.

Real-life example — a Tuesday morning at NorthMaple Accounting

TASK: follow one ordinary bad event through a company with layers and the same company without them.

LINK TO THE LECTURE: this is defensible and cyber-resilient applied to a real situation, and the scenarios are rows from the resilience assessment of Chapter 7 of the Final Project.

08:40 on a Tuesday. An accountant opens an attachment she should not have opened. It happens to careful people every week.

Without layers: her workstation runs it; her account is a local administrator; her account reaches the whole file server; the file server has no separate backup. By 09:15 the client records are encrypted and the firm cannot invoice.

With the five layers: her workstation still runs it — layers one and two did not catch this one. But her account is not an administrator, so damage stops at her own files. She can reach the client-records folder and nothing else. The intrusion detection system records unusual traffic at 08:41. The 02:00 backup sits on storage her account cannot write to. Same event, same mistake: a bad morning and a restored folder, instead of a closed business. Nothing in that story required a better firewall. It required more layers.

Interactive version: [player_o2_defence_in_depth.html](#) — four situations tested against five layers, one step at a time.

4. Where the company touches the outside world

Class 1 — Course Overview, Cyberdefense Fundamentals and Perimeter Security

Three words, used exactly

- An asset is any machine, service or account the company owns and must protect.
- An entry point (also called a perimeter element) is a place where traffic from outside is allowed to reach an asset.
- The attack surface is the complete list of entry points — not the dangerous-looking ones, all of them.
- An attack vector is the route somebody takes through an entry point. The vector is the road; the entry point is the door it arrives at.

An entry point is not a mistake. NorthMaple needs a public website, e-mail, and remote access. Those doors are the business. Your job is to know exactly how many there are and to put the strongest controls on those specific ones. The one people forget is the guest Wi-Fi: a wireless signal does not stop at the wall, so anybody in radio range is standing at a door.

Production reality, September 2026

Threat reporting through 2025 and 2026 describes the same shift: reconnaissance and first contact are increasingly automated with AI. Microsoft security researchers described AI accelerating infrastructure discovery and persona development, compressing the time between choosing a target and first contact. Palo Alto Networks Unit 42 reported that scanning for a newly disclosed vulnerability can begin within about fifteen minutes of its announcement, often before defenders have finished reading the advisory. KnowBe4 reported that around 85.8% of phishing attacks in a recent six-month window were AI-driven, up from about 79.9% in 2024.

Draw exactly one conclusion from those numbers.

The conclusion is NOT that attackers have magic now. The doors are the same doors: website, mail, remote access, wireless. AI did not invent a new entrance.

The conclusion IS that being unknown is no longer a defence. A ten-person firm can no longer assume nobody is looking, because the looking is automated, continuous and cheap. So the defence has to be structural, not lucky: the list, and then the layers on the list.

The same tools, on your side

Every capability described above is available to you free and open-source, running on your own machine with no account and no internet connection. You will use these defensively, starting in LAB_01.

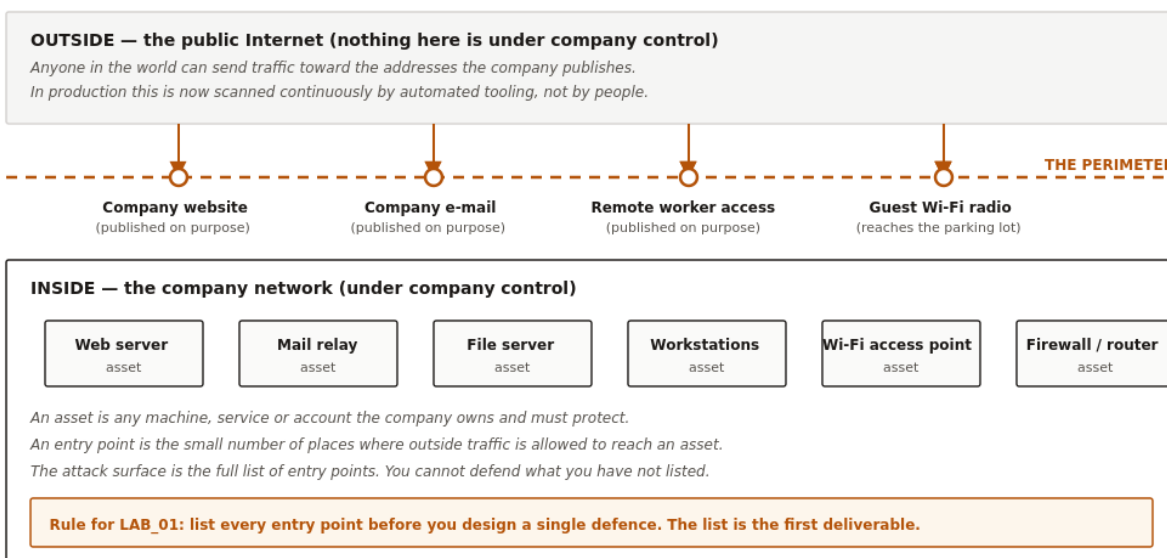
Free / open-source tool	What it is	Official site
Ollama	Runs open-weight models locally from one command	https://ollama.com
Jan	Desktop application, privacy-first, fully local	https://jan.ai
Open WebUI	Self-hosted web interface over a local runner	https://openwebui.com
GPT4All	Beginner-friendly desktop app, modest hardware	https://www.nomic.ai/gpt4all
LocalAI	Self-hosted, runs on your own hardware	https://localai.io

Four defensive uses, and three hard limits

1. Explain a configuration you inherited — paste a firewall rule set, ask what each rule allows.
 2. Review your own design — paste your zoning table, ask what questions a reviewer would ask.
 3. Summarize logs — ask what is unusual in two thousand lines. It gives you somewhere to start, not a verdict.
 4. Recognize AI-written phishing — bad spelling is no longer a warning sign, and that expectation is getting people caught.
- It runs locally, so the company's information stays in the company.
 - You verify everything before it touches a configuration. A confident wrong answer looks exactly like a confident right answer, and you remain fully and solely responsible for your own actions (Legal Notice, sections 1 and 5).
 - You disclose it: the model name, and the exact prompt, in every chapter.

Figure 1 — Where the company touches the outside world

NorthMaple Accounting Inc. (fictional) — every arrow crossing the dotted line is an entry point



Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 1 — The perimeter line, the four entry points crossing it, and the internal assets.

Real-life example — counting NorthMaple's doors

TASK: reduce an inventory of seven systems to the short list the outside world can actually reach. LINK TO THE LECTURE: this is the entry-point identification of LAB_01, and its output is the first deliverable of your Course Procedure Manual.

For each system a defender asks one yes-or-no question: can somebody outside the company reach this? Not “is it important” — the file server is the most important asset in the building and it is not an entry point. Website: yes. Mail relay: yes. Remote access: yes. Guest wireless: yes, and this is the one people forget. File server, workstations, backup target: no. Four out of seven. That number tells you where the strongest controls go and what every reviewer will point at first.

Code illustration — building the entry-point list (Python 3)

TASK: read the inventory, ask each system one question, print the entry-point list and the size of the attack surface. LINK TO THE LECTURE: LAB_01 entry-point identification, written as a program so it cannot quietly skip a system. Nothing is installed and nothing connects anywhere.

```
# A list is a numbered collection of things. Here it will hold every system the company owns.
systems = [
    # Each system is written as a dictionary: a label, the value it holds. "name" is what we call the machine.
    {"name": "Company website", "zone": "DMZ", "reachable_from_internet": True},
    # The mail relay accepts messages from outside, so it is also published on purpose.
    {"name": "Mail relay", "zone": "DMZ", "reachable_from_internet": True},
    # Remote-worker access is published so that staff outside the office can connect back in.
    {"name": "Remote access (VPN)", "zone": "Perimeter", "reachable_from_internet": True},
    # The guest wireless radio leaves the building, so it counts as reachable from outside the walls.
    {"name": "Guest Wi-Fi radio", "zone": "Guest", "reachable_from_internet": True},
    # The file server holds client financial records and must never be reachable from outside.
    {"name": "Client file server", "zone": "Server", "reachable_from_internet": False},
    # Staff workstations start connections outwards, but nobody outside may start a connection to them.
    {"name": "Staff workstations", "zone": "User", "reachable_from_internet": False},
    # The internal backup target is written to from inside only, so it is not an entry point either.
    {"name": "Backup target", "zone": "Server", "reachable_from_internet": False},
]
# We make an empty list now, and we will fill it with only the systems the outside world can reach.
entry_points = []
# The word "for" means: take every system in the list, one at a time, from the first to the last.
for system in systems:
    # We ask a single yes-or-no question about the system we are looking at right now.
    if system["reachable_from_internet"]:
        # If the answer is yes, this system is an entry point, so we add it to the entry-point list.
        entry_points.append(system)
        # We print the decision so a human can read what the program decided and why.
        print("ENTRY POINT :", system["name"], "- zone", system["zone"])
    # The word "else" covers the opposite case: the answer to the question was no.
    else:
        # We print the decision for internal systems too, because a complete list is the point of the
        # exercise.
        print("internal      :", system["name"], "- zone", system["zone"])
# The function len() counts how many items are in a list; here it counts the entry points we collected.
total = len(entry_points)
# The last line prints the number that matters: the size of the attack surface we now have to defend.
print("ATTACK SURFACE:", total, "entry point(s) out of", len(systems), "systems")
```

Output:

```
ENTRY POINT : Company website - zone DMZ
ENTRY POINT : Mail relay - zone DMZ
ENTRY POINT : Remote access (VPN) - zone Perimeter
ENTRY POINT : Guest Wi-Fi radio - zone Guest
internal      : Client file server - zone Server
internal      : Staff workstations - zone User
internal      : Backup target - zone Server
ATTACK SURFACE: 4 entry point(s) out of 7 systems
```

Step by step

1. The program writes down every system the company owns. In a real firm this list comes from purchase records and a walk around the office, never from memory — the commonest cause of a breach is a machine nobody remembered was connected.
2. Each system carries three facts: name, zone, and whether the outside can reach it. That third fact decides everything else.
3. An empty entry-point list is prepared. Empty is the correct starting state: nothing is an entry point until it is shown to be one.
4. The loop visits systems one at a time. A defender who checks “most” systems has not checked the network, and a loop cannot get bored on system six.
5. One question per system. Both answers are printed, because the value is a complete record, not a short one.
6. len() counts the result: four entry points.
7. That number is the attack surface. Hardening, firewalls, detection and encryption all spend their effort on those four places first.

Interactive version: [player_01_perimeter_inventory.html](#)

5. Cutting the network into zones

Class 2 — Cyberdefense Fundamentals and Perimeter Security — Q_01

A flat network is one where every machine can talk to every other machine. On a flat network the security of the whole company equals the security of its weakest machine — not the average, the weakest. Zoning is the fix: divide the network into groups of systems that need similar protection, and control what may cross between them.

Zone	Trust	What lives there	Why it is separate
Internet	0	Everybody else in the world	Nothing here is under company control.
DMZ (Demilitarized Zone)	1	The public web server	Strangers connect to it all day, so it is the most likely to be compromised.
Guest Wi-Fi	1	Visitor phones and laptops	The company does not manage these devices at all.
User zone	2	Staff workstations and staff Wi-Fi	Managed machines, known people, ordinary work.
Server zone	3	File server, client records, backups	The reason the company has a security budget.

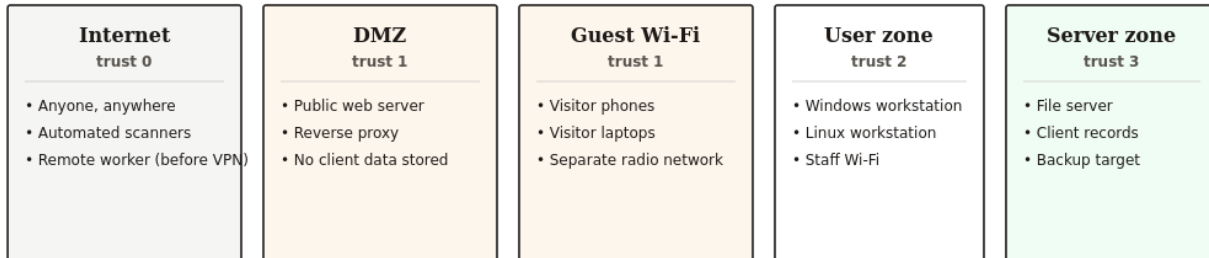
A DMZ is a zone for systems that must be reachable from the internet, arranged so a compromise of those systems reaches nothing else. It exists because the public web server is the most exposed machine you own, so you assume it will be compromised one day and place it where that is survivable. That assumption is the mature version of security thinking: not that it will fail, but that you cannot prove it will not.

The rule of the zoning table

Every system sits in exactly one zone. Every allowed flow between zones has a written justification. And the line nobody writes down: anything not in the table is denied. A network that allows everything except a list of bad things can never be finished, because that list is infinite. A network that denies everything except a written list of good things is finished the day the list is written.

Figure 3 — The zoned design of NorthMaple Accounting Inc.

Five zones. Traffic between zones is allowed only where a written justification exists.



NETWORK FIREWALL — the only path between zones (LAB_05 turns each allowed flow below into one rule)

The zoning table: every allowed flow, and why it exists

From zone	To zone	Service / protocol	Written justification
Internet	DMZ	HTTPS 443	The public must reach the company website.
User zone	Server zone	SMB / NFS file access	Staff need the client-records folder to do their work.
User zone	Internet	HTTPS 443, DNS 53	Staff need the web and name resolution.
Guest Wi-Fi	Internet	HTTPS 443, DNS 53	Visitors get internet access and nothing else.
Remote worker	User zone	VPN only	Remote staff reach internal data only through the encrypted tunnel.
DMZ	Server zone	DENIED	A compromised web server must not reach client data.
Guest Wi-Fi	User zone	DENIED	A visitor device is never trusted with staff systems.

Anything not listed in this table is denied. That default is what makes the design defensible.
Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 3 — The five zones, the firewall between them, and the full zoning table.

Real-life example — “where does the website go?”

TASK: place one machine in the correct zone and follow what that single decision prevents. LINK TO THE LECTURE: this is the core decision of LAB_01 part 2.

Wrong answer one: in the server zone, because both are servers. Strangers connect to the web server all day, so you have placed the most likely machine to be compromised next to the client financial records with nothing in between. Wrong answer two: in the user zone, because there is space — now strangers have a permitted path into where your staff work.

Right answer: the DMZ, its own zone, with two rules. Internet may reach it on HTTPS port 443, because that is the business need. And the DMZ may not reach the server zone at all — no exceptions, no “just for the database”. In eleven weeks, row three of your resilience template reads “the public web server in the DMZ is compromised”, and because of tonight’s decision your honest answer is: withstands, because the firewall denies DMZ to Server.

Interactive version: [player_03_zoning_validator.html](#) — checks a zoning table against both rules and prints PASS or the exact repair list. Companion deliverable: [LAB01_zoning_workbook.xlsx](#), which checks itself as you type.

6. Trust levels, and the tools that watch the border

Class 2 — Cyberdefense Fundamentals and Perimeter Security — Q_01

Give each zone a number from 0 to 3 recording how much control the company has over what happens inside it. Then compare the two numbers on any flow.

- Going down in trust — more controlled to less controlled, such as staff browsing the web. Normal. Write it down and move on.
- Going up in trust — less controlled to more controlled. This is the direction attacks travel. Every one needs to be written down, justified, narrowed to one service and inspected.
- Staying level — two zones you separated on purpose. A flow between them needs a very strong reason or it should not exist.

So “Internet to DMZ on HTTPS” climbs, and that is fine: justified, narrowed to one port, inspected. “DMZ to Server” also climbs, and it is not fine, because no acceptable justification exists. Same direction, opposite verdict. The direction tells you where to look; the justification tells you what to decide.

Figure 4 — Trust levels: which direction needs a control

Traffic going up in trust is the dangerous direction. It always needs an inspecting control.

		TO this zone				
		Internet (0)	Guest (1)	DMZ (1)	User (2)	Server (3)
FROM	Internet (0)	same zone	UP in trust inspect + justify	UP in trust inspect + justify	UP in trust inspect + justify	UP in trust inspect + justify
	Guest (1)	DOWN in trust usually allowed	same zone	SAME level keep separate	UP in trust inspect + justify	UP in trust inspect + justify
	DMZ (1)	DOWN in trust usually allowed	SAME level keep separate	same zone	UP in trust inspect + justify	UP in trust inspect + justify
	User (2)	DOWN in trust usually allowed	DOWN in trust usually allowed	DOWN in trust usually allowed	same zone	UP in trust inspect + justify
	Server (3)	DOWN in trust usually allowed	DOWN in trust usually allowed	DOWN in trust usually allowed	DOWN in trust usually allowed	same zone

How to read this table:

Find the source zone on the left, then the destination zone across the top.

An orange cell means the flow must be written down, justified and inspected before it is allowed.

Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 4 — Every zone pair, and which crossings climb in trust.

Tool	What it does	Lab
Network firewall (pfSense, OPNsense)	Allows or blocks traffic between zones, according to your table	LAB_05
Host firewall (Defender Firewall, UFW, firewalld)	The same idea on a single machine, for when something is already inside	LAB_03

Tool	What it does	Lab
IDS / IPS (Snort, Suricata)	Detection reports suspicious traffic; prevention blocks it	LAB_04
VPN (WireGuard, OpenVPN)	Lets a remote worker cross the border over an encrypted tunnel	LAB_06
Logging and monitoring	Records what crossed, so a question next month has an answer	Throughout

Note the shape of that list: the firewall decides, the IDS notices, the VPN carries, and the logs remember. Four different jobs. A student who thinks “we have a firewall, we are covered” has one layer and three gaps.

Abbreviations: IDS is Intrusion Detection System. IPS is Intrusion Prevention System. UFW is Uncomplicated Firewall. VPN is Virtual Private Network. SSH is Secure Shell. HTTPS is HyperText Transfer Protocol Secure.

Real-life example — the request that should be refused

TASK: work out the trust direction of four requested flows and identify the one that must be denied. LINK TO THE LECTURE: each flow you approve becomes a firewall rule you write in LAB_05 and defend out loud in Class 12.

1. The website must be reachable by the public. Internet (0) to DMZ (1). Climbs, justified. Approved, narrowed to HTTPS 443, inspected.
2. Staff need the web. User (2) to Internet (0). Descends. Approved, written down.
3. The developer asks for the website to reach the file server “just for the client portal”. DMZ (1) to Server (3). Climbs two levels, into the most protected zone, from the most exposed machine. Denied — if a portal needs data, the data comes to it in a controlled way, into its own copy, containing only what it needs.
4. A visitor asks to print from the guest wireless. Guest (1) to User (2). Climbs. It sounds harmless, which is exactly why it gets approved in real companies. Denied, or given one tightly scoped path to one printer.

Neither person in requests three and four is malicious; both have a real problem. The reason to write the trust table down is so the answer comes from the design and not from who asked most persuasively on a Friday afternoon.

Code illustration — which flows climb in trust (PowerShell)

TASK: give each flow a trust number at both ends, decide whether it climbs, descends or stays level, and flag the climbing ones. LINK TO THE LECTURE: it turns Figure 4 into a repeatable check, and its output is the review sheet for LAB_05. It changes nothing on the computer.

```
# A hash table stores pairs. Here each zone name is paired with its trust level, a number from 0 to 3.
$TrustLevel = @{
    # The internet is outside our control, so it receives the lowest possible trust: zero.
    "Internet" = 0
    # The guest wireless network carries visitor devices we do not manage, so it stays very low.
    "Guest" = 1
    # The DMZ holds machines exposed on purpose, so it is trusted a little, but not much.
    "DMZ" = 1
    # The user zone holds managed staff workstations, so it is trusted more than the DMZ.
    "User" = 2
    # The server zone holds the client financial records and is the most trusted zone in the design.
    "Server" = 3
}
# The list of flows we want to check. Each flow says where traffic starts and where it is going.
$Flows = @(
    # A flow from the internet into the DMZ: the public reaching the company website.
    [pscustomobject]@{ From = "Internet"; To = "DMZ"; Service = "HTTPS 443" }
    # A flow from staff workstations down to the internet: normal web browsing.
```

```
[pscustomobject]@{ From = "User";      To = "Internet"; Service = "HTTPS 443" }
# A flow from the DMZ into the server zone: this is the dangerous one we want the check to catch.
[pscustomobject]@{ From = "DMZ";       To = "Server"; Service = "SMB 445" }
# A flow from the guest network into the user zone: visitors reaching staff machines.
[pscustomobject]@{ From = "Guest";     To = "User";   Service = "Any" }
}
# ForEach-Object runs the same block of instructions once for every flow in the list.
$Flows | ForEach-Object {
    # Look up the trust number of the zone where this flow starts.
    $fromLevel = $TrustLevel[$_.From]
    # Look up the trust number of the zone where this flow is going.
    $toLevel = $TrustLevel[$_.To]
    # If the destination is more trusted than the source, traffic is climbing, which is the risky direction.
    if ($toLevel -gt $fromLevel) {
        # Climbing flows are never simply allowed. They must be inspected and justified in writing first.
        $verdict = "UP in trust - inspect and justify, or deny"
    }
    # If the destination is less trusted, traffic is descending, which is normally acceptable.
    elseif ($toLevel -lt $fromLevel) {
        # Descending flows still get written down, but they do not raise the same alarm.
        $verdict = "DOWN in trust - normally allowed"
    }
    # The remaining case is two zones at the same level, such as the DMZ and the guest network.
    else {
        # Two zones at the same trust level are kept apart on purpose, so this flow needs a very strong
        reason.
        $verdict = "SAME level - keep the zones separate"
    }
    # Print one clear line per flow so the whole table can be read at a glance.
    Write-Output ("{$0,-9} -> {1,-9} {2,-11} : {3}" -f $_.From, $_.To, $_.Service, $verdict)
}
```

Output:

```
Internet -> DMZ      HTTPS 443 : UP in trust - inspect and justify, or deny
User     -> Internet HTTPS 443 : DOWN in trust - normally allowed
DMZ      -> Server   SMB 445  : UP in trust - inspect and justify, or deny
Guest    -> User     Any      : UP in trust - inspect and justify, or deny
```

Step by step

1. Each zone gets a trust number recording how much control the company has over it. The numbers are a tool for thinking, not a measurement.
2. The requested flows are listed — in your own design these come straight from the zoning table.
3. The loop reads two numbers per flow: the trust where it starts and the trust where it is going.
4. Destination higher than source means climbing: inspect and justify, or deny. This is the direction attacks travel.
5. Destination lower means descending: normal, still written down, so you can answer “what can leave?” as well as “what can enter?”
6. Equal numbers mean two zones separated on purpose; a flow between them needs a very strong reason.
7. Read the output as a review sheet. Three flows climb. Internet to DMZ is justified and inspected. DMZ to Server and Guest to User have no acceptable reason and become deny rules — and that DMZ-to-Server deny is the single line that stops a compromised web server from reaching client financial records.

Interactive version: [player_o4_trust_direction.html](#)

7. A prioritized checklist, a team that watches, and proof that it holds

Class 2 — Cyberdefense Fundamentals and Perimeter Security — Q_01

The CIS Critical Security Controls

Published free by the Center for Internet Security, the CIS Critical Security Controls answer the question every beginner actually has: out of everything, what do I do first? Version 8.1, released in 2024, contains 18 controls made up of 153 safeguards — a safeguard being one specific, measurable action. They sort into three Implementation Groups; Implementation Group 1, called essential cyber hygiene, is 56 safeguards aimed at small organisations with limited expertise. NorthMaple is exactly an Implementation Group 1 company, and so are most of the places you will work.

The first six controls in plain language: know your devices, know your software, know your data, configure things securely, manage accounts, control access. The first three are all “know”. Before any defensive tool, the framework asks you to make lists — the same instruction as section 4 of this handout, arrived at independently.

The SOC

A SOC (Security Operations Center) is the team responsible for watching continuously and acting when something is found. Not a room — a function, which a small firm usually buys rather than builds. The loop is five steps: collect logs into one place, detect something unusual, triage (a person decides whether it is real), respond by containing and restoring, and improve by turning the finding into a new rule. Then round again.

Step one is collect, and collecting only works if the network has a shape. On a flat network everything is normal, because everything already talks to everything. Your zoning table is what makes detection possible at all: zones create expectations, and detection is the business of noticing broken expectations.

In production in 2026, AI has landed hardest on triage. Alert volumes exceed what people can read, so models do the first pass and surface what looks unusual. The judgement stays with the human. That is the correct division of labour.

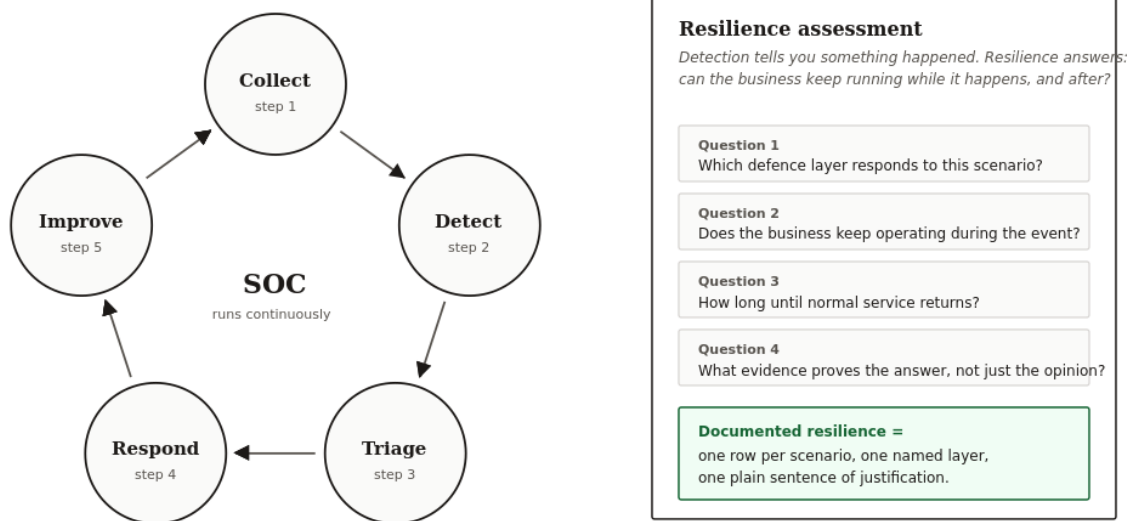
How resilience is assessed and documented

Resilience is not assessed by asking “are we secure?” — that question has no answer. It is assessed by naming a specific scenario and answering four questions: which defence layer responds; does the business keep operating; how long until normal service returns; and what evidence proves the answer. That is the shape of Chapter 7 of your Final Project: ten scenarios, the layers that respond, a verdict of withstands, partly or does not, and one plain sentence of justification.

“Does not withstand” is a valid, full-marks answer when it is true and you say what you would add. Ten confident “withstands” rows for a design that clearly cannot is not an assessment, it is optimism — which is the opposite of the job.

Figure 5 — The monitoring loop, and what resilience adds to it

A SOC (Security Operations Center) runs the left loop. Resilience is the right-hand column.



Cyber Defense (420-D03-AB) — Cyber.SoHo — Educational Hub © 2026 — fictional company, isolated laboratory only

Figure 5 — The five-step SOC loop and the four questions of a resilience assessment.

Real-life example — NorthMaple's first hygiene score

TASK: answer six essential-hygiene questions honestly, turn the “no” answers into a work plan, and produce both a defensive review request for a free local AI model and the required AI disclosure row. **LINK TO THE LECTURE:** this joins the CIS Controls to the academic-integrity rule of the Legal Notice, section 11.

The owner asks “are we secure?” That question has no answer, so you replace it with six that do. Written list of every device? Yes. Every piece of software? No. Do you know which folder holds client records? Yes. All default passwords changed? No — nobody has checked the wireless access point since it was installed. Own named account per person? Yes. Each account reaches only what its role needs? Yes. Four out of six.

What you produced matters more than the number: an honest baseline you can measure again in six weeks, a work plan of exactly two finishable items, and a sentence that is true. “We are secure” ages badly. “Four of six, and here are the two we are fixing” does not.

Interactive version: [player_o5_hygiene_and_ai_review.html](#) — scores the checklist, builds the review request from your real gaps, and prints the AI disclosure row with the prompt already inside it.

8. LAB_01 and Q_01

LAB_01 — Defensible Network Architecture and Zoning

1. Set up your isolated laboratory: VirtualBox, or your own personal free-tier AWS or Azure account. Isolated virtual network. Take a snapshot before you change anything.
2. Draw the network diagram of NorthMaple Accounting Inc., marking every perimeter element and entry point. Use Figure 1 as your model.
3. Start page one of your Course Procedure Manual: the environment setup. Tonight, not later.
4. Open LAB01_zoning_workbook.xlsx. Place every system in exactly one zone. Write every allowed flow with its justification.
5. Run player_03_zoning_validator.html against your table, or read the workbook's own check sheet. Submit only on PASS.

Deliverable: the finished network diagram plus the zoning table. This becomes the architecture chapter of your Final Project and Chapter 1 of your Course Procedure Manual. If you used an AI tool for any part of it, write the disclosure row now, while you still remember the prompt — nobody has ever reconstructed a prompt accurately three weeks later.

Q_01 — what is in it

Short, multiple choice, 2.5%, taken strictly from Classes 1 and 2. Know these:

- Definitions: cyber defense, defense-in-depth, cyber resilience.
- Perimeter elements and entry points — what they are, and why a needed door is not a mistake.
- The purpose of network zones and trust levels — including why the DMZ exists and what “anything not in the table is denied” means.
- The basic role of a SOC — the five-step loop.

Two sentences that will carry you through most of Q_01

You cannot defend what you have not listed.

Five imperfect layers beat one strong wall, because they fail differently.

9. Links used, with a short explanation of each

Before opening any link, verify the address with the free VirusTotal URL (Uniform Resource Locator) scanner. That instruction is section 10 of the course Legal Notice and applies to links in this document exactly as to any other. Every link below points to the organisation's own official website; none is an endorsement, and Cyber.SoHo does not control any external site.

VirusTotal URL scanner — check any address before opening it: <https://www.virustotal.com/gui/home/url>

Standards, frameworks and official bodies

CIS Critical Security Controls v8.1 — 18 controls, 153 safeguards, free: <https://www.cisecurity.org/controls/v8-1>

CIS Benchmarks — free hardening checklists per operating system (LAB_03): <https://www.cisecurity.org/cis-benchmarks>

NIST Cybersecurity Framework — the broader framework the CIS Controls map onto: <https://www.nist.gov/cyberframework>

MITRE ATT&CK — free public catalogue of techniques attackers use, by stage: <https://attack.mitre.org>

Canadian Centre for Cyber Security — Canada's national authority, small-business guidance: <https://www.cyber.gc.ca>

CISA — United States cybersecurity agency, public advisories and free guidance: <https://www.cisa.gov>

Law that applies to you

RCMP — Cybercrime and the Criminal Code, in plain language with examples: <https://rcmp.ca/en/cyber-choices/cybercrime-and-criminal-code>

Criminal Code of Canada — the primary source for sections 342.1, 342.2 and 430(1.1): <https://laws-lois.justice.gc.ca/eng/acts/C-46/>

Tools named in this handout

VirtualBox — free virtualization for your isolated laboratory: <https://www.virtualbox.org>

AWS Free Tier — cloud alternative; monitor the limits, all costs are yours: <https://aws.amazon.com/free/>

Microsoft Azure free services — the other cloud alternative: <https://azure.microsoft.com/en-us/pricing/free-services/>

pfSense — free open-source firewall and router appliance (LAB_05): <https://www.pfsense.org>

OPNsense — the equivalent alternative (LAB_05): <https://opnsense.org>

Snort — free open-source intrusion detection (LAB_04): <https://www.snort.org>

Suricata — the equivalent alternative (LAB_04): <https://suricata.io>

WireGuard — free open-source VPN, recommended for LAB_06: <https://www.wireguard.com>

OpenVPN Community Edition — the established alternative (LAB_06): <https://openvpn.net/community/>

OpenSSL — free cryptography toolkit, used in the Class 14 exercise: <https://www.openssl.org>

Free, open-source AI tools — defensive use, inside your laboratory only

Ollama — runs open-weight models locally from one command: <https://ollama.com>

Jan — open-source desktop application, privacy-first: <https://jan.ai>

Open WebUI — self-hosted web interface over a local runner: <https://openwebui.com>

GPT4All — beginner-friendly desktop application: <https://www.nomic.ai/gpt4all>

LocalAI — self-hosted, runs on your own hardware: <https://localai.io>

Videos referenced in the lecture

Open each link and confirm it is available and under fifteen minutes before relying on it. Videos are removed or made private without notice; nothing in this session depends on one.

Segment 1 — Defense in Depth: <https://www.youtube.com/watch?v=hQXvsfoEhfg>

Segment 1 backup — Defense in Depth strategy: <https://www.youtube.com/watch?v=tDRdO4ppB0g>

Segment 2 — Your Attack Surface Is Bigger Than You Think: <https://www.youtube.com/watch?v=Tuii5XiVCfw>

Segment 2 backup — What Is an Attack Surface: https://www.youtube.com/watch?v=6D-iK8_sMw0

Segment 3 — What is a DMZ, and why every company has one:

<https://www.youtube.com/watch?v=TA32GNMQxpl>

Segment 4 — Zero Trust Explained in 4 mins: <https://www.youtube.com/watch?v=yn6CPQ9RioA>

Segment 4 backup — Zero Trust Explained in 7 Minutes: <https://www.youtube.com/watch?v=h0IAV97lwPI>

Segment 5 — What is a security operations center (SOC): <https://www.youtube.com/watch?v=vuyNFuWv58A>

Segment 5 — CIS Controls: <https://www.youtube.com/watch?v=6OqnCxdncX4>

10. Third-party video notice, and how this material is licensed

Videos are linked, never copied. Every video referenced is reached by a link to the original platform. Nothing is downloaded, re-hosted, re-uploaded, transcribed, embedded as a copy, or reproduced in any form. Viewers reach the creator's own page, where the creator receives the view.

No affiliation, no endorsement. Cyber.SoHo has no affiliation with, sponsorship by, or endorsement from any platform, channel, creator, company, product or service named here, including without limitation Google (YouTube), TikTok, IBM, Cisco, Microsoft, Amazon, Oracle, Netgate, Deciso, the Center for Internet Security, and the publishers of every tool listed above. Third-party videos, comments, re-uploads, edits, reactions and translations are not verified and not endorsed by Cyber.SoHo and remain the sole responsibility of their authors.

Rights remain with their owners. Each video is the property of its creator and the platform hosting it, and remains subject to that platform's Terms of Service and community rules. All product names, logos and brands are trademarks of their respective owners, used here for identification and education only.

Basis for the reference. Links are provided as external references for classroom education, with attribution to the source, without reproduction of the work and without commercial exploitation. If any rights holder objects to being linked from this material, the link will be removed on request — contact Cyber.SoHo.

Link safety. Links are provided for convenience only and are not endorsements. Cyber.SoHo does not control external websites and takes no responsibility for their content, availability or safety. Verify any link with the VirusTotal URL scanner before opening it.

This material. © 2026 Cyber.SoHo. All rights reserved. Cyber.SoHo is the author and exclusive owner of this handout, its figures, its code players and its supporting files. Enrolled students receive a limited, personal, non-transferable, non-exclusive licence to use it for their own study; it does not permit redistribution, re-publication, resale, public posting or commercial use, in whole or in part, without prior written permission. The work you create in this course — your labs, your project, your manual — belongs to you.

Independence. This material is originally written for this course. Cybersecurity uses a shared professional vocabulary — “defence in depth”, “least privilege”, “network zoning” — used by the whole industry. Its use implies no link with any other author, publisher, training company or certification body.

No professional advice. This material is educational. It is not legal advice and it is not professional security consulting. An organisation that needs to protect a real infrastructure must consult qualified professionals. For any question about your own legal situation, consult a lawyer licensed in your

jurisdiction. Before this material is reused or republished outside the course, a review by a lawyer licensed in the Province of Quebec is recommended.

Student Handout — Classes 1 and 2 — Cyber Defense (420-D03-AB) — Version 1.0 — Cyber.SoHo

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !

ALL Rights Reserved